

Mini-SOC AustralPay

Portafolio de Deteccion y Respuesta a Incidentes - Proyecto 1

por Diego Araya - laboratorio de ciberseguridad

Un centro de operaciones de seguridad **construido desde cero**, y una intrusión completa **ejecutada contra él** para probar — y mejorar — su capacidad de detección. Diseño, ataque, detección y respuesta, de punta a punta.

El proyecto

AustralPay es una fintech ficticia de laboratorio. Sobre ella monté un mini-SOC funcional — el sistema que un equipo de seguridad usa para vigilar, detectar y responder a ataques — y luego me puse en los dos lados: el del atacante que intenta entrar, y el del analista que lo caza. El objetivo no fue solo *que funcione*, sino demostrar **criterio**: distinguir una alerta real del ruido, reconstruir un ataque completo, y ser honesto sobre lo que el sistema no ve.

El recorrido — cinco etapas

1

Fundamentos

Desplégé el SIEM (el cerebro del SOC) desde cero: Wazuh sobre Docker, reproducible y documentado.

Demuestra: [Infraestructura](#)

2

Visibilidad

Conecté tres equipos — servidores y estación de trabajo — para que todo lo que ocurre en ellos llegue al SIEM, con telemetría enriquecida en Windows.

Demuestra: [Instrumentación](#)

3

Detección

Lancé ataques reales contra el laboratorio y escribí reglas de detección propias cuando las estándar no bastaban.

Demuestra: [Ingeniería de detección](#)

4

Respuesta

Automaticé el bloqueo de atacantes, sumé monitoreo de integridad de archivos con trazabilidad de usuario, y retención de logs alineada al estándar de pagos (PCI-DSS).

Demuestra: [Respuesta y cumplimiento](#)

5

Cadena de ataque

Diseñé y ejecuté una intrusión completa de 8 fases y la investigué como un analista de primer nivel, documentando qué se detectó y qué no.

Demuestra: [Respuesta a incidentes](#)

Nota: AustralPay es un laboratorio ficticio construido íntegramente por mí, con fines de aprendizaje y portafolio. No representa una empresa ni un incidente real.

El caso estrella: una intrusión completa, de principio a fin

La pieza central del proyecto: **simulé el ataque completo que sufriría una fintech** — desde un correo de phishing hasta el robo de datos de pago — y luego lo **investigué desde cero**, como lo haría un analista en su primer día de trabajo.

El ataque atravesó ocho fases en dos horas y media. El sistema solo generó **cuatro alertas dispersas**; las demás fases pasaron en silencio. El trabajo de análisis fue reconstruir la historia completa a partir de esas pocas señales — entrar por una alerta menor y tirar del hilo hasta descubrir toda la intrusión — y entregar un informe listo para escalar. El hallazgo clave: una alerta grave había pasado desapercibida dos horas antes, y haberla atendido habría detenido el ataque.

8	2h 35m	2	4 / 6
fases de ataque	duración total	equipos comprometidos	detectadas / puntos ciegos

Cobertura de detección — honesta

Mapeé la intrusión al marco **MITRE ATT&CK** (el estándar de la industria para describir ataques). Tan importante como lo que el sistema detecta es documentar lo que se le escapa: de trece técnicas usadas, cuatro se detectaron con fuerza, tres parcialmente, y seis fueron puntos ciegos — cada uno con su recomendación de mejora.



Competencias demostradas

- Despliegue y administración de SIEM (Wazuh)
- Telemetría de endpoint (Sysmon)
- Respuesta a incidentes (triage estilo N1)
- Respuesta automatizada (Active Response)
- Análisis de gaps de detección
- Ingeniería de reglas de detección
- Simulación de ataques (purple team)
- Marco MITRE ATT&CK
- Integridad de archivos (FIM) + PCI-DSS
- Documentación técnica y ejecutiva

Nota de honestidad. AustralPay es un laboratorio ficticio; no representa ninguna empresa ni incidente real. Todo el trabajo — diseño del entorno, ejecución del ataque, detección, respuesta y documentación — es propio, realizado de forma autónoma con fines de aprendizaje y portafolio.